

UST-2026-09-30-27

Acceso al hub, a StartUp Admin y a las salas Builders/Pitch tras el aviso de una tester: se cierra la cerradura de cartón de Design (esta noche), y después tres llaves en orden — PIN de Cloudflare por correo · contraseña · tercera llave (3 posiciones de una clave de 8 o TOTP) — con sesión de 24 horas como máximo y una sola sesión abierta por persona

PROPUESTA v3 (30-sep-2026, madrugada; revisada por tres lentes independientes — seguridad, usabilidad de las founders, viabilidad contra el código — antes de entregarla) · Entrega A DESPLEGADA por Juanjo a las 00:25 (po268, ns-build 3009-001913, webdeploy c307745 + 47412f5): en vivo, /v1/ sirve 0 apariciones de «hubCode.length === 6) {» y 1 de «if (false) {», cortinilla y RPC intactas, /hub sigue tras Access, smoke-prod verde con el check nuevo (D1 resuelta por el hecho) · Entrega B (tres llaves, 24 h, una sesión por superficie) se construye tras la validación fila a fila de D2–D15. Antes que nada: D13 — comprobar en Cloudflare la política Include y los Logs de Access.

1 · El pedido, literal

Juanjo (chat de Claude Code, 30-sep-2026 ~00:05 y ~00:40), tras el aviso de una tester («they were able to access the builders page») y sus propias pruebas en Chrome incógnito, escritorio e iPhone:

«We have an urgent task to do tonight, it has been reported by one of our testers that they were able to access the builders page, I have tried myself and I have observed the following behaviours».

«1. In Incognito Mode in Chrome, I tried to use random digits and didn't go through, today's six digit code is [seis cifras], ACTION: to reinforce it: let's make it 8 digits and change it to [ocho cifras] and ask for three random digits».

«2. I observed that in Desktop and Mobile after going through the random digits authentication and email cloudflare in desktop (that's OK) and in mobile going straight to the builders (not asking for email OTP, doesn't seem OK), I go through the user/password authentication in both platforms (that is OK), ACTION, set the default tap for opening the builders in Piloto, startup admin in the landing page as it is, but without user/password authentication nothing should be shown».

«3. After going through the two digits authentication is presenting the claudfare email OTP challenge and response, no issues observed in the Desktop Chrome but in the Mobile (IOS/iPhone) it is not asking for the email OTP, ACTION: put all behind the user and password first, second cloudfare OTP authentication, and third three out of six digits or the MFA as for the three digits out of six».

«4. let's put back OTPT optional, we will get always the user/password, cloudfare email OTP, random 3 pins and/or OTPT (optional) if OTPT is activated the random 3 pins would not be asked for».

«The startup admin, is asking for a six digit email OTP, the Pitch access should ask for the same, but all behind Cloudfare email OTP authentication instead of supabase six digits, so StartUp Admin and Pitch, should ask first for email and password for authentication, second for email OTP as second factor authentication and third the 3 random digits out of 8 or the TOTP (MFA authenticator)».

«Finally the session should not last more than 24 hours».

(~00:40) «and adding to all the improvements, only one session can be open at a time».

Lectura de ingeniería: (a) hay un agujero REAL pero pequeño — la cerradura de Design debajo de la nuestra — que se cierra con un cambio de una línea y un deploy (Entrega A); (b) el resto del pedido es un REDISEÑO de la autenticación de las tres superficies privadas (hub, StartUp Admin, salas) que deshace tres de las siete decisiones de UST-17 «un candado» (26-sep): vuelven la tercera llave y el cierre de sesión, y la sesión de Access baja de 30 días a 24 h. Es carril técnico (decide Juanjo), pero Pilar, Lucía y María Paula lo notan cada día: por eso D12 les pide probar el circuito ANTES de que caduque la primera sesión, para no repetir el 26-sep («no me deja entrar»). Dos puntos del pedido no se pueden construir tal cual y se proponen de otra forma: el ORDEN (Cloudflare Access va siempre primero porque vive en el borde de la red, antes de que exista una página donde teclear una contraseña — D2) y las CLAVES (las dos cifras del pedido han pasado por el chat y quedan quemadas por la regla del 4-sep; las nuevas las teclea Juanjo en el SQL y viven en el gestor compartido — D5).

Lo que el pedido llama «OTP de Cloudflare» y «OTP de Supabase» (dos códigos distintos, como el 26-sep)

El PIN que llega al Gmail al entrar en /hub/* o en admin. lo manda Cloudflare Access (segundo factor, sesión por dispositivo). El código de seis cifras que hoy pide StartUp Admin lo manda Supabase (signInWithOtp, sustituye a la contraseña). El pedido quiere que StartUp Admin use contraseña + PIN de Cloudflare, como el hub, y retirar el OTP de Supabase (F6, D9).

Lo que NO es un fallo

«En el móvil no pide el OTP por correo»: la cookie de Access dura 30 días por dispositivo (UST-17 D2, hecho en Zero Trust por Juanjo el 26-sep). En incógnito no hay cookie y sí lo pide. Con D6 (24 h) lo pedirá cada día en cada dispositivo.

2 · Lo que hay HOY (medido esta madrugada: curl a producción, código servido, integrate.py, RPC y tests)

Qué	Medido
Entrada a las salas	Pie de la Web V2 → ` /v1/?sala=builders` o `?sala=pitch` (bloque `ns-sala-deeplink`) → tarjeta de Design con NUESTRA cortinilla `ns-room-gate` (r14i): 6 puntos, dos posiciones al azar elegidas por el NAVEGADOR, teclado barajado, `POST /rest/v1/rpc/ns_room_gate_check` con la anon key (la RPC lee `room_gate`, tabla RLS sin políticas; el código no está en el HTML — lo vigila web-tests r14h). Al acertar: `location.href = /hub/full-hub-gated-site.html?r=builders` → Cloudflare Access. Sin límite de intentos: con posiciones elegidas por el cliente, 300 llamadas bastan para recuperar el código entero.
EL AGUJERO	En el motor de Design (` /v1/index.html`, texto plano): `verifyHub: () => { if (this.state.hubCode.length === 6) { this.setState({ hubUnlocked: true }) ... } }` — mira la LONGITUD, no el valor (`hubCode: ""`, sin comparación). Nuestra cortinilla esconde su ` <input >`="" (`builderstack`,="" (el="" (su="" ...`,="" 900="" `="" `display:none`="" `setinterval`="" a="" abren="" access:="" access»,="" al="" app»="" apuntan="" blanco="" botón="" caja="" cambiar="" cifras="" con="" cualesquiera="" de="" del="" demo)="" desaparecido,="" desde="" design="" detrás="" el="" en="" ese="" estado:="" estática="" founder).<="" full="" ha="" herramientas="" hub="" hueco,="" iframe="" input),="" la="" las="" los="" montar="" motor="" ms="" navegador,="" no="" o="" page="" para="" pitch="" placeholder="Enter code" quien="" quitando="" re-esconde="" redibuja="" repo="" room»="" sala="" sea="" seis="" si="" solo="" su="" td="" the="" una="" vez="" vuelve="" y="" «builder="" «explore="" «open="" «request="" →="" ↗»=""/>
Lo que está cerrado (medido)	` /hub`, `/hub/`, `/hub/index.html`, `/hub/full-hub-gated-site.html` (con y sin `?r=`), `/hub/pilot.html`, `/hub/pitch.html`, `/hub/admin-mis-console.html`, `/hub/mfa.html`, `/hub/investors-business-case.html` → 302 a `larama-familia-2026.cloudflareaccess.com`. `nutrisync-collective.pages.dev/hub/...` → 301 al dominio (r26-c). `admin.nutrisynccollective.com` → 302 a Access. `/builders` y `/pitch` → 200, pero sirven la Home de la V2 (78 KB, sin cortinilla ni contenido de sala).
Access (capa 1)	Política del hub: 8 correos (foto en `hub/access.html`: 2 de Juanjo, 2 de Lucía, 2 de Pilar, 2 de María Paula; la verdad es el panel). Sesión: «1 month» global y en las dos aplicaciones (UST-17 D2). El team domain es de la cuenta (también aloja laramagonzalez.com).
Hub (capa 2)	Contraseña de Supabase (`signInWithPassword`) UNA vez por dispositivo; el refresh token renueva sin fin; cierre por inactividad APAGADO (`LIMITE=0`, UST-17 D3). 28 de las 29 páginas de /hub llevan su propio bloque de login (MIS: overlay `adminLogin`; herramientas: `id="gate"`), pero el contenido ESTÁTICO se pinta antes de la contraseña — en el gated de Design (Overview/Builders) se ve la sala entera tras Access sin sesión; los DATOS llegan por RPC y esas RPC exigen `is_admin_mfa()` = «es admin» (UST-17 D1/D5: ya no mira `aal`). `ns-default-route`: sin hash → `#/builders`. TOTP: opcional, `nsMfaReforzar()` en la barra, `mfa.html`; ninguna RPC lo exige.
StartUp Admin (admin.)	Access → `signInWithOtp` de Supabase (código de 6 cifras por correo, `shouldCreateUser:false`) → `verifyOtp` → dentro; TOTP opcional con aviso clicable; `LIMITE=0`. `is_sa_admin()` = «es admin». `admin-tests` vigila que la ÚLTIMA definición de `is_sa_admin` no mire `aal` (test «un candado») y la forma de `afterSignIn`.
Sesiones	Access 30 días/dispositivo. Supabase: JWT de 1 h + refresh token sin caducidad absoluta. Cliente: sin límite absoluto. Es decir: hoy una sesión del hub dura hasta que alguien cierra sesión a mano. OJO: los ajustes de sesión del panel de Supabase (Authentication → Sessions: time-box, single session) son de TODO el proyecto — la app y la PWA de las testers usan el MISMO Supabase — así que no sirven para limitar solo a las admins.
Baseline (lo que se restaura)	Web en producción po267 (`ns-build 2909-233153`, webdeploy `b2e5cc6`, desplegada 29-sep 23:5x) · proyecto `b0cc280` (adminsita dentro) · appdev `5741f18` · RPC: `ns_room_gate_check` (2026-08-06-room-gate.sql), `is_admin_mfa` / `is_sa_admin` (2026-09-26-un-candado-auth.sql), `admin_mfa_readiness` (2026-08-05) · Access «1 month» (panel) · Supabase Sessions por defecto (panel). Marcha atrás web: Pages → Deployments → Rollback; SQL: `create or replace` a la definición anterior (idempotente); paneles: volver a «1 month» / desactivar time-box.

Analogía: Es una puerta con una cerradura buena (Access) y, dentro, un armario con dos cierres: el nuestro, que pregunta al servidor, pegado encima de uno de cartón que se abre empujando. La tester empujó el de cartón y vio el interior del armario — no la casa. Esta noche se quita el de cartón; después se decide cuántas llaves lleva la casa y cuánto dura cada una abierta.

3 · Lo que se construiría (F1–F10) — Entrega A esta noche · Entrega B tras la firma

Qué	Qué se construye	Cómo se verifica
F1 · ENTREGA A · Cerrar la cerradura de cartón de Design (D1)	En el bloque <code>`ns-room-gate`</code> de <code>`integrate.py`</code> , sobre el índice de la v1: <code>`verifyHub: () => { if (this.state.hubCode.length === 6) {` → `if (false) {`</code> . La sala de Design deja de abrirse desde su propio botón; la única forma de «entrar» sigue siendo nuestra cortinilla, que no abre la sala: salta al hub (Access). Nada más cambia: ni la cortinilla, ni las tarjetas, ni el estilo (la segunda aparición de <code>`hubCode.length === 6`</code> es el color del botón y se queda). <code>web-tests r27-p: `publish/v1/index.html`</code> NO contiene <code>`hubCode.length === 6) {`</code> . Deploy po268.	Puerta: <code>web-tests</code> en rojo con el fichero de hoy y en verde con el cambio. Vivo: en <code>`/v1/?sala=builders`</code> , con el <code>`display:none`</code> retirado a mano, teclear seis cifras + «Verify & enter» NO abre nada; la cortinilla sigue mandando al hub (Access). <code>smoke-prod: check nuevo «v1: sin desbloqueo por longitud»</code> .
F2 · ENTREGA B · Clave de 8 cifras y reto de 3 posiciones que elige el SERVIDOR, con límite de intentos (D4, D5, D11)	<code>`room_gate.code`</code> pasa a 8 cifras (<code>`__CLAVE_PUERTA_8`</code> : la teclea Juanjo en el SQL antes de Run; no va a git ni al chat). Nueva <code>`ns_room_challenge()`</code> → <code>`{challenge_id, positions[3]}`</code> guardado en <code>`room_gate_challenges`</code> (uuid, posiciones, <code>`ip_hash`</code> = sha256(<code>`cf-connecting-ip`</code> primero, si no el primer <code>`x-forwarded-for`</code> , + sal), <code>`created_at`</code> , <code>`used`</code> ; caduca a los 3 min; si esa IP ya tiene un reto abierto se devuelve el MISMO — sortear retos gratis hasta que salgan posiciones cómodas es la forma barata de atacar; ≤10 retos/15 min por IP). <code>`ns_room_gate_check(p_challenge uuid, p_digits text)`</code> : UN intento por reto, compara las 3 cifras, marca <code>`used`</code> ; 10 fallos/15 min por IP o ≥50 fallos/15 min en total → <code>{ok:false, wait:true}`</code> + fila en <code>`security_alerts`</code> (D11). Las tres tablas nuevas ( <code>`room_gate_challenges`</code> , <code>`team_key`</code> , <code>`admin_key_ok`</code> ) nacen con RLS activada y SIN políticas, <code>`revoke all`</code> a anon/authenticated: solo las RPC (security definer) las tocan. pg_cron horario borra retos viejos; tope de filas vivas. La cortinilla pide las posiciones que devolvió el servidor (8 puntos, 3 marcados) y enseña «Demasiados intentos: espera 15 minutos Too many attempts: wait 15 minutes» si hay bloqueo (ES EN). La RPC vieja de 2 posiciones SIGUE viva hasta que la web nueva esté en producción (SQL → Deploy → SQL de cierre que la retira): entre el Run y el deploy la cortinilla vieja no se queda muerta (r27-e, orden de entrega).	Arnés <code>`tools/sql-arnes/2026-09-30-tres-llaves/`</code> : reto caduca · reto no se reutiliza · misma IP recibe el mismo reto abierto · 10 fallos por IP bloquean (rojo) · 50 fallos globales cierran la puerta y dejan alerta (rojo) · acierto entra (verde) · <code>`set local role anon`</code> + INSERT directo en <code>`room_gate_challenges`</code> → 42501 (la tabla no se escribe por REST). Vivo: incógnito, 10 fallos seguidos → bloqueo con mensaje; tras 15 min, entra. La clave de la puerta no está en git ni en <code>`publish/`</code> : <code>web-tests r14h</code> deja de buscar un literal (ya no existe) y pasa a exigir que junto a <code>`ns-room-gate`</code> no haya ningún número de 8 cifras y que la RPC llamada sea la de reto (<code>`ns_room_challenge`</code>).
F3 · Tercera llave del hub, exigida en el SERVIDOR (D3, D10)	Clave de equipo de 8 cifras (<code>`team_key`</code> , <code>`__CLAVE_EQUIPO_8`</code> , distinta de la de la puerta si D4 = dos) y <code>`ns_team_key_challenge()`</code> / <code>`ns_team_key_check()`</code> que devuelven <code>{ok:false}`</code> a quien no esté en <code>`admins`</code> — comprobado DENTRO de la función, no solo por GRANT: en este proyecto toda tester de la app es <code>`authenticated`</code> — y, para las admins, mismo patrón de reto/límite que F2 (5 fallos/15 min por usuaria + cerrojo global ≥15 fallos/15 min entre todas, D11). Al acertar, la propia función inserta la fila en <code>`admin_key_ok(user_id = auth.uid(), superficie hub admin, session_id = auth.jwt()->'session_id', verified_at)`</code> — nunca desde un parámetro —, ÚNICA por (persona, superficie) (D14); <code>`ns_key_from_totp()`</code> hace lo mismo tras un TOTP válido (exige <code>`aal2`</code> en el JWT), y el pase directo la hereda en dos pasos — fila pendiente de la Edge + <code>`ns_key_claim()`</code> del receptor (D15). <code>`is_admin_mfa()`</code> e <code>`is_sa_admin()`</code> v3: es admin AND existe <code>admin_key_ok</code> para ESTA sesión con <code>verified_at > now() - 24 h`</code> (sin rama «aal2» que salte la fila, D3). Así la tercera llave no es un adorno de la interfaz: sin fila, ninguna RPC admin responde. Si la cuenta tiene un factor TOTP verificado, la barra ofrece el TOTP (<code>`nsMfaReforzar`</code> , ya existe) con el enlace «usar la clave del equipo» debajo: cualquiera de los dos vale (D10). Todos los textos nuevos ES EN (patrón <code>`T(es,en)`</code> de la barra).	Arnés SQL: <code>`is_admin_mfa()`</code> false sin fila (aal1 Y aal2); true con fila de esta sesión; false con fila de OTRA sesión o de hace 25 h; <code>`ns_team_key_check()`</code> false para una <code>`authenticated`</code> que no es admin; <code>`set local role authenticated`</code> + INSERT directo en <code>`admin_key_ok`</code> → 42501; 15 fallos globales cierran la llave y dejan alerta. <code>admin-tests</code> : la última definición de <code>`is_sa_admin`</code> exige la fila de <code>`admin_key_ok`</code> (el test «un candado» se reescribe: hoy exige lo contrario). Vivo: tras la contraseña, sin la llave, el MIS enseña el reto y no datos.
F4 · Un solo muro para todo /hub (D8)	El login sale de las 28 páginas y pasa a la BARRA (<code>`hub-navbar.html`</code> , que ya está en todas): al cargar cualquier /hub, el <code>`<body>`</code> se oculta aal2. Sin sesión → pantalla completa con correo + contraseña y «¿Olvidaste la contraseña? Forgot password?» (<code>`resetPasswordForEmail`</code> → <code>`reset.html`</code> , que ya existe: hoy la recuperación es un curl de Juanjo); con sesión sin llave → reto de 3 posiciones (u overlay TOTP, con «usar la clave del equipo»). Todos los textos ES EN; el muro no depende de una sola RPC: si <code>`ns_key_session_ok()`</code> no contesta, enseña el error con su nombre (r12-b9), nunca una página en blanco. El gated de Design incluido: su contenido estático ya no se ve tras Access sin contraseña. Los bloques de login de cada página quedan (no molestan) y se retiran en goteo.	<code>web-tests r27-p</code> : la barra contiene el muro y todas las páginas /hub la llevan (ya se cuenta). jsdom: sin token → <code>`body`</code> oculto y formulario visible; con token sin llave → reto; con llave → contenido. Vivo: incógnito → Access → contraseña → llave → contenido, en esa secuencia, en escritorio e iPhone.
F5 · Un solo por defecto: Piloto (D7)	La cortinilla salta a <code>`/hub/pilot.html`</code> desde la tarjeta Builders y a <code>`/hub/full-hub-gated-site.html?r=investors`</code> desde la tarjeta Pitch (hoy <code>`HUB`</code> es una constante única: pasa a depender de la tarjeta pulsada); <code>`ns-default-route`</code> sin hash manda a <code>`pilot.html`</code> en vez de <code>`#/builders`</code> ; <code>`hub/index.html`</code> (hoy → <code>incidents.html</code>) manda a <code>`pilot.html`</code> . ▢ Overview sigue en la barra. StartUp Admin sigue donde está en la landing.	<code>web-tests</code> : se REESCRIBEN los dos tests <code>`default-route`</code> (líneas ~53–59: fallback e <code>`r`</code> inválido → <code>pilot.html</code>) y se añade el de los dos destinos de la cortinilla; <code>smoke-prod</code> : el check «v1: Builders entra con ?r=» (73–78) pasa a exigir los dos destinos nuevos. Vivo: puerta Builders → ... → Piloto; puerta Pitch → ... → Pitch.

Qué	Qué se construye	Cómo se verifica
F6 · StartUp Admin: contraseña en vez del OTP de Supabase; PIN de Cloudflare como segundo factor; tercera llave igual que el hub (D9)	<code>`repos/adminsite/index.html`</code> : <code>`bindGate`</code> pasa de <code>`signInWithOtp`</code> a <code>`signInWithPassword`</code> ; tras entrar, <code>`afterSignIn`</code> exige la tercera llave (TOTP si hay factor; si no, 3 de 8 contra <code>`team_key`</code>) y <code>`is_sa_admin`</code> v3 lo respalda. Deploy StartUp Admin (su <code>`command`</code>).	admin-tests, tres tests cambian: (1) «toda RPC que llama la página existe en el SQL» solo lee <code>`2026-08-05-startup-admin.sql`</code> (línea ~211) → pasa a buscar cada RPC en todo <code>`backend-sql`</code> (si no, las RPC nuevas lo ponen en rojo y abortan el Deploy StartUp Admin); (2) <code>`signInWithOtp`</code> desaparece de <code>`bindGate`</code> , <code>`signInWithPassword`</code> presente, forma nueva de <code>`afterSignIn`</code> ; (3) «un candado» → «tres llaves». Vivo: admin. → Access → contraseña → llave → libros.
F7 · Pitch = el mismo circuito que Builders	La sala Pitch solo tiene contenido dentro de /hub (iframe y «Open full page 7»); con F1 su cortinilla de cartón muere, con F4 el hub pide contraseña + llave, y con F5 su tarjeta aterriza en Pitch (<code>`?r=investors`</code>). No hace falta una puerta aparte.	Vivo: <code>`/v1/?sala=pitch`</code> → cortinilla → Access → muro → llave → Pitch (<code>`#/investors`</code>).
F8 · Sesión de 24 h como máximo y UNA sesión por persona, SOLO para las admins (D6, D14)	Los ajustes de sesión del panel de Supabase (time-box, single session) NO se tocan: son de todo el proyecto y cerrarían cada día la app a las testers del piloto. Se hace con lo nuestro: (1) Cloudflare Zero Trust → Settings → Authentication → sesión global 24 h, y Access → Applications → hub y admin → Session Duration 24 h (panel, Juanjo; deshace UST-17 D2) y, el MISMO día del deploy de B, «Revoke existing tokens» en las dos aplicaciones (las cookies de 30 días emitidas desde el 26-sep siguen vivas hasta que caducan: si no se revocan, el iPhone «no pide el PIN» y parecerá un fallo). La sesión global es del team <code>`larama-familia-2026`</code> , que también sirve laramagonzalez.com: la familia también pasará a 24 h (declarado; alternativa: cuenta de Zero Trust aparte, fuera de alcance); (2) la fila de <code>`admin_key_ok`</code> caduca a las 24 h y es ÚNICA por (persona, superficie): al verificar la llave en un dispositivo se borra la anterior de esa superficie → la sesión antigua deja de pasar <code>`is_admin_mfa`</code> en el siguiente RPC (una sola sesión por superficie, en el servidor; el pase directo copia la fila, D15); vale igual para quien entra con TOTP, porque el TOTP también acuña la fila (D3); (3) la barra y adminsite llaman a <code>`ns_key_session_ok`</code> (RPC ligera: ¿hay fila viva para ESTA sesión?) al cargar y cada 2 minutos: si no la hay, muro con el motivo («han pasado 24 h» o «has entrado desde otro dispositivo»); (4) cliente: <code>`ns_login_ts`</code> y cierre absoluto a las 24 h por si el servidor no contesta — y al cerrar por 24 h, la barra manda a <code>`/cdn-cgi/access/logout`</code> y de ahí al muro, para que las tres caducidades colapsen en UN momento y la founder vea una sola secuencia PIN → contraseña → llave, no dos interrupciones separadas por minutos. Los avisos son inferencias, bilingües: «Tu sesión se cerró: han pasado 24 h Your session closed: 24 hours have passed» · «Tu sesión se cerró: probablemente has entrado desde otro dispositivo (una sesión por persona) Your session closed: most likely you signed in from another device (one session per person)». El JWT de Supabase sigue vivo (a la app no le afecta), pero sin fila no hay hub. Inactividad: sigue apagada (<code>`LIMITE=0`</code>) salvo que D6 diga lo contrario.	Arnés SQL: segunda verificación de la llave desde otra <code>`session_id`</code> borra la primera; <code>`ns_key_session_ok`</code> false para la sesión vieja; fila de hace 25 h → false. Panel: captura de los ajustes de Access. Vivo: entrar en el iPhone estando dentro en el Mac → el Mac vuelve al muro en ≤2 min; a las 24 h de la llave, el muro con el aviso. Sonda: <code>`admin_key_ok`</code> tiene como mucho UNA fila por (admin, superficie).
F9 · Documentación y avisos	la página de acceso del hub — su ÚNICA fuente es el bloque <code>`_ACCESS_HTML`</code> de <code>`integrate.py`</code> (líneas ~425–452), que se escribe en <code>`publish/hub/access.html`</code> en cada integración; el <code>`hub/access.html`</code> de la raíz del repo es un artefacto viejo (po213) que no se sirve y se marca como histórico — pasa a decir tres llaves, 24 h, una sesión por superficie; la lista de correos sigue siendo foto, <code>`documentation/user-guide`</code> (línea de acceso), <code>`CONTINUIDAD-Llaves-Compartidas.md`</code> (las dos claves nuevas van al gestor compartido, NO al fichero), mensaje de una línea para Pilar, Lucía y María Paula (qué cambia mañana y por qué), Notion sin bloques → hub, CLAUDE.md (invariantes de seguridad: sustituyen a las de «un candado»).	web-tests: access.html con «24h» y sin «30 days»; el muro y los tres avisos en ES y EN (como r14h con la cortinilla). Mensaje enviado (WhatsApp, lo manda Juanjo).
F10 · Tests y puertas	web-tests r27-p (F1, F4, F5), admin-tests (F3, F6), arnés SQL (F2, F3), smoke-prod (v1 sin desbloqueo por longitud; admin. sigue tras Access; /hub/* sigue 302), <code>`datos-en-html`</code> (sin datos nuevos a mano), linkcheck.	Todas en verde en el Deploy; smoke en verde tras el deploy.

4 · Análisis de impacto

Dónde	Qué toca	Qué NO toca
Web (`repos/webdeploy`)	`integrate.py` (bloques `ns-room-gate` y `ns-default-route`), `_integration/hub-navbar.html` (muro + tercera llave + 24 h + logout de Access), bloque `_ACCESS_HTML` de `integrate.py` (texto de la página de acceso), `hub/index.html` (→ pilot.html), `_integration/docs/62-...` (este documento) · Edge `pase-directo` (deja la fila pendiente de la llave) + receptores de la barra y adminsite (`ns_key_claim`) · publish/ por Deploy: po268 (A, hecho) y po269+ (B).	
StartUp Admin (`repos/adminsite`)	`index.html` (`bindGate`, `afterSignIn`, `LIMITE` → cierre absoluto 24 h) · Deploy StartUp Admin.	
Base (`backend-sql`)	`2026-09-30-tres-llaves-a.sql` (nada: A es solo web) · `2026-09-30-tres-llaves-b.sql` : `room_gate` 8 cifras + `room_gate_challenges` + `ns_room_challenge` / `ns_room_gate_check` v2 (anon, con límite) · `team_key` + `ns_team_key_challenge` / `ns_team_key_check` (solo admins, comprobado dentro) · `admin_key_ok` + `ns_key_from_totp` + `ns_key_claim` (pase directo, dos pasos) + `ns_key_session_ok` (¿hay fila viva para esta sesión?; sin prefijo admin_a propósito: la regla 2c de sql-columnas) · `security_alerts` (+ línea en el digest) · cron de limpieza · `is_admin_mfa` / `is_sa_admin` v3 (admin AND fila ≤24 h) · las tres tablas con RLS sin políticas · tablero · y un SQL de CIERRE tras el deploy que retira la RPC vieja de 2 posiciones y registra el as-built. Placeholders `__CLAVE_PUERTA_8__` y `__CLAVE_EQUIPO_8__` que teclea Juanjo antes de Run (D5). Arnés `tools/sql-arnes/2026-09-30-tres-llaves/`.	
Paneles (Juanjo)	Cloudflare Zero Trust: política Include del hub y de admin. (D13, comprobar) · sesión global y de las dos aplicaciones a 24 h (D6) · Logs de Access (D13). Supabase: NADA en Authentication → Sessions (son ajustes de todo el proyecto; la app de las testers los sufrirá).	
Tests	`tools/web-tests.mjs` : r27-p (hecho) · r14h reescrito (sin literal; sin número de 8 cifras junto a la cortinilla; RPC de reto) · los dos `default-route` (~53–59) reescritos a pilot.html · destinos por tarjeta · muro y avisos en ES y EN · access.html con «24 h» y sin «30 days». `tools/admin-tests.mjs` : RPC-existe en todo backend-sql · «un candado» → «tres llaves» (la última definición exige la fila) · forma de `afterSignIn`. `tools/smoke-prod.mjs` : check F1 (hecho) · «Builders entra con ?r=» reescrito a los dos destinos · admin. sigue tras Access. Arnés SQL nuevo `tools/sql-arnes/2026-09-30-tres-llaves/` — PREVIO: los arneses existentes están escritos para el sandbox de Cowork (embedded-postgres linux-arm64, rutas /sessions/...); hace falta la receta darwin-arm64 en el Mac antes de que corra (media hora, dentro de la jornada de B).	
Quién lo nota	Pilar, Lucía, María Paula y Juanjo: cada día y en cada dispositivo, PIN de Cloudflare por correo + contraseña + tercera llave (TOTP o 3 cifras) — una vez al día POR DISPOSITIVO. Quien alterne móvil y portátil en el mismo día entra dos veces (una por dispositivo) y, con D14, la llave del móvil cierra la del portátil en esa superficie; saltar del hub a StartUp Admin no cuenta (el pase directo hereda la llave). Las testers y el público: nada (la web, la app y la PWA no cambian).	
Lo que NO se toca	RLS y las políticas de datos, `service_role` (solo Vault/Edge), las 8 páginas legales, la app y la PWA, el rebote de pages.dev, la waitlist (UST-19), los correos de Access (los 8 de la foto: si el panel dice otra cosa, es D13 y no esta UST). No se rota ninguna credencial (UST-21 D0: nada hasta noviembre) — las claves de la puerta y del equipo son NUEVAS, no rotaciones.	

Estimación: Entrega A, 20 minutos (hecha, pendiente de D1 y del doble clic). Entrega B, una jornada: SQL + arnés (media), barra + adminsite + tests (media), verificación en dos dispositivos con Pilar y Lucía. Riesgo principal: el del 26-sep al revés — cuatro retos en fila dejaron fuera a las founders; por eso B se entrega en UN día, con Access, la llave del servidor y el cliente arrancando a la vez (sesiones de Access revocadas ese día) y con las founders probando ANTES de la primera caducidad (D12).

5 · Decisiones (D1–D15: Juanjo, carril técnico; Pilar y Lucía corroboran y prueban — D12) — propuesta · alternativa · D15 va antes que D14 porque D14 depende de ella

#	Propuesta	Alternativa	Decisión
D1	Entrega A esta noche: neutralizar el desbloqueo por longitud de Design y desplegar po268 (un cambio de una línea, sin efecto en nada más).	Esperar y desplegar A junto con B.	PROPUESTA (Juanjo, 30-sep 00:39) — HECHA: po268 desplegada a las 00:25 y verificada en vivo.
D2	ORDEN de las llaves: Cloudflare Access (PIN por correo) → contraseña de Supabase → tercera llave (TOTP si hay factor; si no, 3 de 8). Access va primero por construcción: vive en el borde de la red, antes de que exista una página donde teclear. La fuerza es la misma que en el orden del pedido; lo que cambia es que ningún desconocido llega siquiera al FORMULARIO de la contraseña (el endpoint de contraseña de Supabase es público con la anon key —la app lo usa—; Access esconde el formulario, no la comprobación: por eso la tercera llave y el límite de intentos van en el servidor).	Orden literal del pedido (contraseña → PIN de Cloudflare → llave): exige sacar el formulario de contraseña a una URL PÚBLICA fuera de Access (más superficie expuesta, misma fuerza). No recomendada.	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D3	La tercera llave se exige en el SERVIDOR y en TODAS las ramas: <code>`is_admin_mfa()`</code> <code>`is_sa_admin()`</code> <code>v3 = admin AND existe fila de `admin_key_ok` para ESTA sesión (<code>`auth.jwt()->>'session_id'`</code>) con <code>`verified_at > now() - 24 h`</code>. El TOTP no salta la fila: la OBTIENE (<code>`ns_key_from_totp()`</code> comprueba <code>`aal2`</code> en el JWT e inserta la misma fila que la clave). Así el reloj de 24 h y la unicidad por superficie valen igual para quien usa TOTP; con «aal2 O fila» no valdrían para nadie con TOTP (sesión sin caducidad absoluta). Sin fila, ninguna RPC admin responde aunque alguien salte la interfaz.</code>	Solo en la interfaz (la barra pide la llave, las RPC no la comprueban). Más simple, pero una llave que no vigila el servidor es un adorno.	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D4	DOS claves de 8 cifras: la de la PUERTA pública (salas; anónimos, con límite de intentos) y la del EQUIPO (tercera llave, solo tras la contraseña). Si un día se adivina la de la puerta, no se ha adivinado nada del hub.	UNA sola clave para puerta y tercera llave (más fácil de recordar; una fuga en la puerta pública debilita el hub).	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D5	Las claves NO viajan por el chat ni por git: el SQL lleva <code>`__CLAVE_PUERTA_8__`</code> y <code>`__CLAVE_EQUIPO_8__`</code> , Juanjo las teclea antes de Run y las guarda en el gestor compartido (ficha nueva en CONTINUIDAD). Las dos cifras del pedido de esta noche se dan por quemadas (regla del 4-sep: un secreto en el chat es un secreto quemado).	Usar tal cual la clave de 8 del pedido (ya ha pasado por el chat y por este documento en cifrado: no recomendada).	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D6	Sesión de 24 h SOLO para las admins, con el reloj que manda en el servidor (la fila de <code>`admin_key_ok`</code> caduca a las 24 h y la comprueba cada RPC), el de Cloudflare (Access GLOBAL + las dos aplicaciones a 24 h, y revocar las sesiones vivas el día del deploy) y el del cliente (la barra cierra a las 24 h con aviso y sale también de Access). Colateral declarado: la sesión global de Zero Trust es de la cuenta y también sirve laramagonzalez.com → la familia pasa a 24 h. Es necesario para que el PIN por correo se pida cada día: con la global a 30 días, una aplicación a 24 h se renueva sin PIN. Los ajustes de sesión del panel de Supabase NO se tocan (son de todo el proyecto: echarían a las testers de la app cada día). Inactividad sigue APAGADA (la del 26-sep). Deshace UST-17 D2/D3; se declara.	Global a 30 días y solo las dos aplicaciones a 24 h: la familia no cambia, el PIN por correo vuelve cada 30 días por dispositivo, y las 24 h las impone igual la llave en el servidor (que es el reloj que de verdad protege). O además cierre por inactividad a los 30 min (UST-06 G1).	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D7	UN solo «por defecto»: Piloto (<code>`/hub/pilot.html`</code>) desde la tarjeta Builders de la cortinilla, desde el gated sin ruta y desde <code>`/hub`</code> (hoy <code>`hub/index.html`</code> manda a Incidencias, r16: quedarían tres destinos distintos). La tarjeta PITCH de la cortinilla lleva a Pitch (<code>`?r=investors`</code> , la vista que ya existe), no a Piloto — la cortinilla tiene hoy un destino fijo para las dos tarjetas y hay que darle uno por tarjeta. □ Overview sigue en la barra; StartUp Admin sigue donde está en la landing.	Dejar <code>`#/builders`</code> (Overview de Design) como hoy y <code>`/hub`</code> en Incidencias.	PROPUESTA (Juanjo, 30-sep 00:39, Word) y CONFIRMADA en el chat a las 01:0x: «Pitch → Pitch, Hub → Pilot, StartUp Admin → as is».

#	Propuesta	Alternativa	Decisión
D8	Muro universal en la barra: en TODA página de /hub (incluido el gated de Design) no se pinta NADA hasta tener sesión y llave; los bloques de login de cada página se retiran en goteo. El muro es experiencia de uso (el HTML estático lo descarga igual quien pasó Access: las 8 founders); la garantía de seguridad es la del servidor — los DATOS solo salen por RPC y las RPC exigen la fila (D3).	Muro solo en las herramientas con datos (MIS, Piloto, Waitlist...); el gated de Design se sigue viendo tras Access.	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D9	StartUp Admin: contraseña de Supabase (<code>`signInWithPassword`</code>) en vez del código de 6 cifras por correo; el PIN de Cloudflare ya es el segundo factor; tercera llave igual que el hub. La misma puerta en las dos superficies.	Mantener el OTP de correo de Supabase ADEMÁS de la contraseña (cuatro retos: el 26-sep otra vez).	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D10	TOTP opcional y NUNCA el único camino: quien tenga factor verificado ve el TOTP primero, pero puede elegir «usar la clave del equipo» (cualquiera de las dos vale como tercera llave y las dos acuñan la MISMA fila de <code>`admin_key_ok`</code> , D3); sin factor, la clave. Móvil perdido con TOTP = se entra con la clave y Juanjo retira el factor (<code>`auth.admin`</code> → DELETE factor, documentado en VERIF · Recuperación). Nadie pierde su factor; <code>`mfa.html`</code> sigue.	TOTP obligatorio para quien lo tenga (sin la clave como alternativa): un móvil perdido deja fuera hasta que Juanjo retire el factor a mano.	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D11	Límites de intentos, en el servidor: PUERTA pública — un intento por reto (3 min), ≤10 retos/15 min por IP (hash con <code>`cf-connecting-ip`</code> primero + sal; se reutiliza el reto abierto de esa IP en vez de sortear otro), 10 fallos/15 min por IP (umbral alto: una oficina o el móvil tras CGNAT comparten IP), y un cerrojo GLOBAL: ≥50 fallos/15 min en la puerta, sea de donde sea → puerta cerrada 15 min + fila en <code>`security_alerts`</code> (la ve el digest). Limpieza por <code>pg_cron</code> cada hora (<code>`created_at < now() - 1 h`</code>) y tope de filas vivas (la lección de las 630.083 filas). CLAVE DE EQUIPO — 5 fallos/15 min por usuario y cerrojo global ≥15 fallos/15 min entre todas (el secreto es compartido: 100 cuentas de usar y tirar no deben sumar 500 intentos) → llave cerrada 15 min + alerta. Las founders siempre pueden entrar por /hub directo aunque la puerta pública esté cerrada. Mensajes honestos y bilingües, no silencio.	Sin límite (como hoy): el reto de posiciones se recupera entero en unas cientos de llamadas.	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D12	Corroboración y PRUEBA de Pilar y Lucía: el mismo día del deploy de B, entran desde móvil y escritorio siguiendo el What to Test, y Juanjo confirma en los Logs de Access. Mensaje de una línea preparado (F9).	Desplegar y avisar después (el 26-sep fue exactamente esto).	PROPUESTA (Juanjo, 30-sep 00:39, Word).
D13	ANTES de A: Juanjo mira en Zero Trust la política Include del hub y de admin. (deben ser los 8 correos) y los Logs de Access (ningún correo ajeno). Si aparece uno: incidente aparte (UST propia, rotación y aviso a Audidat), no esta UST.	Darlo por bueno sin mirar.	PROPUESTA (Juanjo, 30-sep 00:39) y HECHA (chat, 01:0x: «D13 all OK»): la política Include del hub y de admin. es la de los 8 correos y en los Logs de Access no hay ningún correo ajeno. Lo que vio la tester era la plantilla estática de Design; nada tras Access.
D15	Pase directo hub ↔ StartUp Admin: SE CONSERVA y lleva la llave, en DOS pasos (la Edge acuña el pase y termina; la sesión nueva solo nace cuando el receptor lo consume en el navegador, así que la Edge no puede conocer su <code>`session_id`</code>): (1) la Edge <code>`pase-directo`</code> (service role; ya exige <code>`admins`</code>), si la sesión de origen tiene llave viva, deja una fila «pendiente» en <code>`admin_key_ok`</code> ligada al hash del pase (superficie destino, <code>`session_id`</code> nulo, caduca con el pase); (2) el receptor, justo tras <code>`verify`</code> , llama a <code>`ns_key_claim(p_pase)`</code> (authenticated) que ata esa fila a <code>`auth.jwt()->>'session_id'`</code> . Sin llave de origen no hay fila pendiente y el salto pide la llave (correcto). Saltar de superficie no cuenta como otro dispositivo.	Retirar el pase directo: con D9 StartUp Admin tiene la misma puerta (contraseña + llave), el salto sería un login normal más la llave — más simple, un reto más por día.	PROPUESTA (Juanjo, 30-sep 00:39): pase directo conservado; la herencia de la llave se construye en dos pasos (fila pendiente de la Edge + <code>ns_key_claim</code> del receptor).

#	Propuesta	Alternativa	Decisión
D14	UNA sesión abierta por persona y por SUPERFICIE (hub · StartUp Admin), SOLO para las admins: la fila de `admin_key_ok` es única por (persona, superficie) — verificar la llave en un dispositivo borra la del anterior en esa superficie, que pierde el hub en el siguiente RPC (≤2 min) y ve el muro con el aviso. El pase directo hub ↔ StartUp Admin NO cuenta como otro dispositivo: la Edge `pase-directo` (service role, ya comprueba `admins`) copia la llave a la sesión nueva cuando la de origen la tiene — si no, el salto pediría la tercera llave otra vez y al volver, contraseña y llave (el 26-sep). NO se usa «Single session per user» del panel de Supabase (es de todo el proyecto: cerraría la app a cualquier tester con dos dispositivos) ni `signOut({scope:'others'})` (cerraría la app en el móvil de una founder que también es tester). Access no tiene este ajuste, y no hace falta: sin llave no se ve nada (D3, D8).	No limitar; solo las 24 h.	PROPUESTA (Juanjo, 30-sep 00:39, Word).

6 · Baseline, verificación y marcha atrás

Momento	Qué se comprueba
A · antes del deploy	web-tests r27-p en rojo con el fichero de hoy y en verde con el cambio; pre-deploy, datos-en-html, linkcheck en verde; zip po268 solo cambia `v1/index.html` (+ sello) y el doc 62.
A · tras el deploy (MEDIDO 30-sep 00:27)	curl `v1/` en vivo: 0 apariciones de `hubCode.length === 6` {}, 1 de `verifyHub: () => { if (false) {`, cortinilla y RPC presentes (1 · 1); raíz con sello 3009-001913; /hub/full-hub-gated-site.html → 302 a Access; smoke-prod del Deploy: «v1: el motor de Design no desbloquea la sala por longitud (UST-27 F1)» ✓ y producción sana. Pendiente a mano (Juanjo o una founder): seis cifras en el input de Design destapado no abren nada.
B · antes	Arnés SQL (F2, F3) en verde con los casos en rojo probados; admin-tests y web-tests nuevos; Deploy Web + Deploy StartUp Admin con sus puertas; capturas de los tres ajustes de panel.
B · después	Incógnito escritorio + iPhone: Access → contraseña → llave → Piloto; 5 fallos → bloqueo; la llave en el móvil cierra el Mac en ≤2 min; a las 24 h, el muro. La app de una tester sigue abierta (nada del proyecto cambió). Logs de Access: solo los 8 correos. Pilar y Lucía: «entro» desde los dos dispositivos (D12).
Recuperación (autoservicio o quién)	Contraseña olvidada: enlace del muro → correo de Supabase → `reset.html` (autoservicio). TOTP con móvil perdido: se entra con la clave del equipo (D10) y Juanjo retira el factor (`auth.admin.mfa.deleteFactor`, receta en secrets/README). Clave del equipo olvidada: ficha «Clave del equipo NutriSync» en el gestor compartido (custodia: Juanjo; copia: Pilar). Clave de la puerta: ídem; y las founders no la necesitan (entran por /hub/pilot.html en favoritos). Bloqueo por 5 fallos: 15 minutos, sin llamar a nadie.
Desviaciones antes del deploy (revisión de cuatro lentes sobre B, 30-sep 01:4x)	(1) ElSQL B se parte en DOS: parte 1 (tablas, RPC, puente con límites para la RPC vieja) y parte 2 (puertas v3) que se ejecuta AL FINAL, con web, StartUp Admin y Edge servidos — cero ventana en la que la web vieja pida datos sin llave. (2) F8(4) cambia: al caducar el reloj de 24 h NO se sale de Cloudflare Access (su cookie caduca antes que nuestro reloj y el 2º día mandaba a la founder a la página de logout justo tras el PIN); solo se cierra Supabase en ese dispositivo (scope local) y se enseña el muro con el motivo. (3) StartUp Admin: `signOut({scope:'local'})` (el global cerraría la app en el móvil de una founder). (4) La Edge no hereda una llave sustituida (`superseded_at is null`). (5) La RPC vieja de 2 posiciones queda con los mismos límites por IP y posiciones 0..5 hasta el cierre. (6) Marcha atrás en ORDEN: primero las puertas (un candado), después Pages.
Marcha atrás (ajuste por ajuste, quién)	Access global + 2 apps → «1 month» (Juanjo, panel). SQL → `create or replace` de `is_admin_mfa` / `is_sa_admin` desde `2026-09-26-un-candado-auth.sql` (Juanjo, bandeja; `admin_key_ok`, `team_key` y los retos pueden quedarse: sin RPC que los exija no molestan). Hub → Pages → Deployments → Rollback a po268 (Juanjo) — el muro es JS de la barra: si la RPC `ns_key_session_ok` no contesta enseña el error, no una página en blanco. StartUp Admin → Pages → Rollback (Juanjo). Edge `pase-directo` → redeploy de la versión anterior (Juanjo, `command`).
Registro	Doc 62 as-built con desviaciones fila a fila; PDF firmado + `.sha256`; tablero (`2026-09-30-tres-llaves-tablero.sql`, item P0 en S19); CLAUDE.md; Notion sin bloques → hub.

7 · What to Test (Pilar, Lucía, María Paula — tras la Entrega B)

1. Antes de empezar: ten a mano tu contraseña del hub, tu Gmail (llega el PIN de Cloudflare) y la ficha «Clave del equipo NutriSync» del gestor compartido (8 cifras; te pedirán 3 posiciones). Si tienes app de autenticación, también vale.
2. Escritorio, ventana de incógnito: abre nutrisynccollective.com/hub/pilot.html (tu favorito). Debe pedir, en este orden: el PIN de Cloudflare por correo, tu contraseña y tu tercera llave (el código de la app de autenticación si la tienes, o tres

posiciones de la clave del equipo — puedes elegir). Después: Piloto, sin más preguntas hasta mañana. Todo en español e inglés.

3. iPhone, Safari: lo mismo. Si NO te pide el PIN de Cloudflare es que la sesión antigua de 30 días sigue viva: dilo (no es un fallo) y Juanjo la revoca. Al verificar tu llave en el iPhone, en el Mac verás el muro al recargar o en menos de dos minutos, con el aviso «probablemente has entrado desde otro dispositivo».

4. Desde el hub, pulsa StartUp Admin: debe entrar SIN pedirte otra vez contraseña ni llave (el pase directo hereda la llave). Ya no llega el código de 6 cifras por correo de Supabase.

5. Al día siguiente (24 h después de entrar): vuelve a pedir PIN + contraseña + llave, con el aviso «han pasado 24 h». Antes de esas 24 h, nada.

6. AL FINAL, y solo con la clave del EQUIPO (no con la de la puerta): falla la llave 5 veces seguidas. Debe decir que esperes 15 minutos; te bloquea solo a ti, y a los 15 vuelve a dejarte. No lo hagas con la clave de la puerta de la web: bloquearía 15 minutos a toda tu red (casa u oficina).

7. Si algo no entra, di QUÉ pantalla y a QUÉ hora (captura): cada capa deja rastro distinto (Logs de Access · auth de Supabase · admin_key_ok).

8 · Lecciones grabadas (van también a CLAUDE.md)

Lección	Qué cambia
Una cerradura buena encima de una de cartón es una de cartón	Nuestra cortinilla preguntaba al servidor, pero dejaba VIVO el botón de Design que solo mira la longitud. Tapar no es neutralizar: lo que hay debajo se desactiva (F1), y la prueba lo intenta por debajo (input destapado).
«En el móvil no lo pide» se mide antes de llamarlo fallo	Era la sesión de 30 días por dispositivo decidida el 26-sep. Ante un síntoma de autenticación, primero: ¿qué cookie/sesión lleva ese dispositivo? (r23, r27-c).
Un factor que solo vive en la interfaz no es un factor	La tercera llave se exige en `is_admin_mfa()` / `is_sa_admin()` (D3); si no, cualquiera que salte el overlay llama a las RPC igual.
Las claves no pasan por el chat	Las dos cifras del pedido quedan quemadas (regla del 4-sep). Placeholders en el SQL, la clave la teclea quien la custodia y vive en el gestor compartido (D5).
Cuatro retos en fila = cero retos (26-sep) — y la cura no es quitar retos, es UNO al día	Tres llaves, una vez cada 24 h, en las dos superficies con la misma puerta; y las founders prueban antes de la primera caducidad (D12).
Un factor sin camino de vuelta es un bloqueo con fecha	TOTP sin alternativa, contraseña sin «olvidé», llave sin ficha: cada uno deja fuera a una founder hasta que alguien con acceso técnico la rescate (26-sep). Toda llave nace con su recuperación escrita y con quién la ejecuta (VERIF · Recuperación).
El pase directo acuña sesión nueva: «una sesión» se define por superficie	Hub → StartUp Admin crea otra `session_id`; una regla ingenua de «una sesión por persona» mataría el hub en cada salto. La llave se copia en la Edge y la unicidad es por (persona, superficie).
`PEDIDO.extra` son objetos {titulo, texto}	UST-23/24/25 los escribieron como cadenas y el generador los pintó en blanco (lo cazó la verificación del 29-sep). Este documento los escribe como objetos; los tres anteriores se corrigen aparte (texto firmado: se avisa a las founders).

9 · La cadena

Paso	Estado
UST	Propuesta 30-sep 00:1x (commit af34591) → v3 tras tres revisiones (3ade296) → FIRMADA 30-sep 00:39 (este documento).
Sign-off	Juanjo (D1–D15, carril técnico) · Pilar y Lucía corroboran y PRUEBAN (D12) · María Paula avisada (entra igual).
Dev	A: `integrate.py` + web-tests (hecho, pendiente de D1). B: SQL + arnés → barra + `ns-default-route` + access.html → adminsite → tests.
Test	web-tests r27-p · admin-tests «tres llaves» · arnés SQL con casos en rojo · pre-deploy · smoke-prod (+2 checks).
Deployment	A: Deploy Web po268. B: SQL en la bandeja (con las claves tecleadas por Juanjo) → Deploy Web → Deploy StartUp Admin → panel de Access (24 h global y en las dos aplicaciones).
Verification	Incógnito + iPhone, 5 fallos, cambio de dispositivo, salto al StartUp Admin, 24 h · Logs de Access · sonda `admin_key_ok` (≤1 fila por admin y superficie) · `security_alerts` vacía.

Paso	Estado
hub + Notion	Doc 62 (propuesta → as-built) + adjunto; ítem P0 en S19 (` 2026-09-30-tres-llaves-tablero.sql `); Notion sin bloques → hub; CLAUDE.md (invariantes nuevas, UST-17 D1–D3 superadas).

Firmas

Persona	Rol	Conforme	Fecha
Juanjo Cebrián	Ingeniería y producto — decide D1–D15 (carril técnico)	Sí — «Propuesta» en las 15 filas, Word devuelto el 30-sep-2026 00:39	30-sep-2026 00:39
Pilar González	CEO — corrobora y PRUEBA el circuito (D12); dueña de la organización de Supabase	PENDIENTE (corroboración + prueba)	
Lucía Cebrián	COO — corrobora y PRUEBA el circuito (D12)	PENDIENTE (corroboración + prueba)	